



CONTROLES DE SEGURIDAD

APENDICE A



A05 CONTROLES ORGANIZACIONALES

A05 CONTROLES ORGANIZACIONALES

A.5.1

POLÍTICAS PARA LA SEGURIDAD DE LA INFORMACIÓN

Se debe definir, aprobar por la dirección, publicar y comunicar a todos los empleados y partes externas relevantes las políticas de seguridad de la información y temas específicos, así como se deben revisar los cambios significativos en intervalos de tiempo planeados, en caso de que ocurran.

A.5.2

ROLES Y RESPONSABILIDADES PARA LA SEGURIDAD DE LA INFORMACIÓN

Todos los roles y responsabilidades de la seguridad de la información deben definirse y asignarse de acuerdo a las necesidades de la organización.

A.5.3

SEGREGACIÓN DE TAREAS

Las tareas en conflicto y áreas de responsabilidad deben segregarse.

A05 CONTROLES ORGANIZACIONALES

A.5.4

RESPONSABILIDADES DE ADMINISTRACIÓN

La administración debe exigir que todo el personal aplique seguridad de la información de acuerdo a lo establecido en la política de seguridad de la información, políticas de temas específicos y procedimientos de la organización.

A.5.5

CONTACTO CON AUTORIDADES

La organización debe establecer y mantener contactos con las autoridades relevantes.

A.5.6

CONTACTO CON GRUPOS DE INTERÉS ESPECIAL

La organización debe establecer y mantener contactos con grupos de interés especial u otros foros de seguridad especializados y asociaciones profesionales.

A05 CONTROLES ORGANIZACIONALES

A.5.7

INTELIGENCIA DE AMENAZAS

La información relacionada con amenazas a la seguridad de la información debe ser colectada y analizada para producir inteligencia de amenazas.

A.5.8

SEGURIDAD DE LA INFORMACIÓN EN LA ADMINISTRACIÓN DE PROYECTOS

La seguridad de la información debe incluirse en la administración de proyectos.

A.5.9

INVENTARIO DE INFORMACIÓN Y OTROS ACTIVOS ASOCIADOS

Un inventario de la información y otros activos asociados, incluyendo los dueños, debe ser desarrollado y mantenido.

A05 CONTROLES ORGANIZACIONALES

A.5.10

USO ACEPTABLE DE LA INFORMACIÓN Y OTROS ACTIVOS ASOCIADOS

Se debe identificar, documentar e implementar reglas para el uso aceptable de la información y de los activos asociados.

A.5.11

DEVOLUCIÓN DE ACTIVOS

El personal y otras partes interesadas deben devolver apropiadamente todos los activos de la organización que tengan en su posesión tras el cambio o terminación de su empleo, contrato o acuerdo.

A.5.12

CLASIFICACIÓN DE INFORMACIÓN

La información debe ser clasificada de acuerdo a las necesidades de la organización, tomando como base la confidencialidad, integridad, disponibilidad y requisitos de las partes relevantes interesadas.

A05 CONTROLES ORGANIZACIONALES

A.5.13

ETIQUETADO DE INFORMACIÓN

Se debe desarrollar e implementar un apropiado conjunto de procedimientos para el etiquetado de la información de acuerdo con el esquema de clasificación de la información adoptado por la organización.

A.5.14

TRANSFERENCIA DE INFORMACIÓN

Las reglas, procedimientos o acuerdos para la transferencia de información deben existir para todo tipo de instalaciones de transferencia dentro de la organización y entre la organización y otras partes.

A.5.15

CONTROL DE ACCESO

Las reglas para el control físico y lógico del acceso a información y otros activos asociados deben ser establecidas e implementadas con base en el negocio y los requisitos de la seguridad de la información.

A05 CONTROLES ORGANIZACIONALES

A.5.16

GESTIÓN DE LA IDENTIDAD

El completo ciclo de vida de las identidades debe ser administrado.

A.5.17

INFORMACIÓN DE AUTENTICACIÓN

La asignación y gestión de información de autenticación debe ser controlada por un proceso de gestión, incluyendo asesoramiento personal de un manejo apropiado de la información de autenticación.

A.5.18

DERECHOS DE ACCESO

Los derechos de acceso a información y otros activos asociados deben ser provisionados, revisados, modificados y eliminados de acuerdo con la política de temas específicos de la organización y reglas para el control de acceso.

A05 CONTROLES ORGANIZACIONALES

A.5.19

SEGURIDAD DE LA INFORMACIÓN PARA LA RELACIÓN CON PROVEEDORES

Los procesos y procedimientos deben definirse e implementarse para gestionar los riesgos de seguridad de la información del tipo relación con proveedor.

A.5.20

ABORDAR LA SEGURIDAD DENTRO LOS ACUERDOS CON PROVEEDORES

Todos los requisitos de seguridad de la información relevantes deben establecerse y acordarse con cada proveedor basado en el tipo de relación existente.

A.5.21

GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN EN LA CADENA DE SUMINISTRO DE LAS TIC

Se deben definir e implementar los procesos y procedimientos para gestionar los riesgos de seguridad de la información asociados con los productos TIC y cadenas de suministros de servicios.

A05 CONTROLES ORGANIZACIONALES

A.5.22

GESTIÓN DE MONITOREO, REVISIÓN Y CAMBIOS A LOS SERVICIOS DE PROVEEDORES

La organización debe monitorear, revisar, evaluar y auditar regularmente los cambios en las prácticas de seguridad de la información de la entrega de servicio de proveedores.

A.5.23

SEGURIDAD DE LA INFORMACIÓN PARA USO DE SERVICIOS DE LA NUBE

Los procesos de los servicios para adquisición, uso, auditoría y salida de la nube deben ser establecidos de acuerdo a los requerimientos de seguridad de la información de la organización.

A.5.24

GESTIÓN, PREVISIÓN Y PREPARACIÓN CONTRA INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

La organización debe prever y prepararse para gestionar incidentes de seguridad de la información definiendo, estableciendo y comunicando los procesos, roles y responsabilidades de la gestión incidentes de seguridad de la información

A05 CONTROLES ORGANIZACIONALES

A.5.25

EVALUACIÓN Y DECISIÓN SOBRE EVENTOS DE SEGURIDAD DE LA INFORMACIÓN

La organización debe evaluar los eventos de seguridad de la información y decidir si son clasificados como incidentes de seguridad de la información.

A.5.26

RESPUESTA A INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

Se debe responder a los incidentes de seguridad de la información de acuerdo con los procedimientos documentados.

A.5.27

APRENDIZAJE DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN

El conocimiento obtenido a partir de los incidentes de seguridad de la información debe utilizarse para reforzar y mejorar los controles de seguridad de la información.

A05 CONTROLES ORGANIZACIONALES

A.5.28

RECOPILACIÓN DE EVIDENCIA

La organización debe definir y aplicar procedimientos para la identificación, recopilación, adquisición y preservación de la evidencia relacionada con eventos de seguridad de la información.

A.5.29

SEGURIDAD DE LA INFORMACIÓN DURANTE INTERRUPCIONES

La organización debe planear cómo mantener la seguridad de la información a un nivel apropiado durante interrupciones.

A.5.30

DISPONIBILIDAD DE LAS TECNOLOGÍAS DE INFORMACIÓN Y COMUNICACIÓN (TIC)

Las TIC deben planearse, implementarse, mantenerse y ponerse a prueba con base en los objetivos de continuidad del negocio y los requisitos de continuidad de las instalaciones de procesamiento de la información.

A05 CONTROLES ORGANIZACIONALES

A.5.31

REQUISITOS LEGALES, ESTATUTARIOS, REGULATORIOS Y CONTRACTUALES

Los requisitos legales, estatutarios, regulatorios y contractuales relevantes para la seguridad de la información y el enfoque de la organización para conocer estos requisitos deben ser identificados, documentados y mantenerse actualizados.

A.5.32

DERECHOS DE PROPIEDAD INTELECTUAL

La organización debe implementar procedimientos apropiados para proteger los derechos de propiedad intelectual.

A.5.33

PROTECCIÓN DE REGISTROS

Los registros deben estar protegidos contra pérdida, destrucción, falsificación, acceso no autorizado y divulgación no autorizada.

A05 CONTROLES ORGANIZACIONALES

A.5.34

PRIVACIDAD Y PROTECCIÓN DE INFORMACIÓN DE IDENTIFICACIÓN PERSONAL

La organización debe identificar y conocer los requisitos considerando la preservación de la privacidad y protección de información de identificación personal de acuerdo a las leyes y regulaciones y los requisitos contractuales

A.5.35

REVISIÓN INDEPENDIENTE DE LA SEGURIDAD DE LA INFORMACIÓN

El enfoque de la organización para la gestión de la seguridad de la información y su implementación, incluyendo personas, procesos y tecnologías deben ser revisados independientemente a intervalos planeados o cuando se ocurran cambios significativos.

A.5.36

CUMPLIMIENTO CON POLÍTICAS, REGLAS Y ESTÁNDARES PARA LA SEGURIDAD DE LA INFORMACIÓN

El cumplimiento de la política de seguridad de la información de la organización, políticas de temas específicos, reglas y estándares deben ser regularmente revisados.

A05 CONTROLES ORGANIZACIONALES

A.5.37

PROCEDIMIENTOS OPERACIONALES DOCUMENTADOS

Los procedimientos operacionales para las instalaciones del procesamiento de la información deben ser documentados y estar disponibles al personal que los necesite.



A06 CONTROLES DE PERSONAS

A06 CONTROL DE PERSONAS

A.6.1

INVESTIGACIÓN

Se deben llevar a cabo verificaciones de antecedentes a todos los candidatos al empleo de acuerdo con las leyes, regulaciones relevantes y la ética, y deben ser proporcionales a los requisitos del negocio, la clasificación de la información a la que se accede y los riesgos percibidos.

A.6.2

TÉRMINOS Y CONDICIONES DEL EMPLEO

Los acuerdos contractuales con los empleados deben indicar sus responsabilidades y las de la organización para la seguridad de la información

A.6.3

CONCIENTIZACIÓN, EDUCACIÓN Y CAPACITACIÓN EN SEGURIDAD DE LA INFORMACIÓN

Todos los empleados de la organización y las partes relevantes interesadas deben recibir concientización, educación y capacitación apropiada y actualizaciones regulares de políticas y procedimientos organizacionales, políticas de temas especiales y procedimientos, cuando sea relevante para sus funciones de trabajo.

A06 CONTROL DE PERSONAS

A.6.4

PROCESO DISCIPLINARIO

Debe haber y comunicarse un proceso disciplinario formal para tomar acciones contra empleados y otros interesados relevantes que hayan cometido una violación a la política de seguridad de la información.

A.6.5

RESPONSABILIDADES EN LA TERMINACIÓN O CAMBIO DE EMPLEO

Las responsabilidades de la seguridad de la información y obligaciones que permanecen válidos después de la terminación o el cambio de empleo deben estar definidos, comunicados a los empleados o contratistas y hacerse cumplir.

A.6.6

ACUERDOS DE CONFIDENCIALIDAD O NO DIVULGACIÓN

Se deben identificar, revisar regularmente, documentar y ser firmados por el personal y otras partes relevantes interesadas, los requisitos para los acuerdos de confidencialidad o no divulgación reflejando las necesidades de la organización para la protección de la información.

A06 CONTROL DE PERSONAS

A.6.7

TRABAJO REMOTO

Se deben implementar medidas de seguridad cuando el personal está trabajando de manera remota para proteger el acceso, proceso o almacenamiento de información fuera de las instalaciones de la organización.

A.6.8

REPORTE DE EVENTOS DE SEGURIDAD DE LA INFORMACIÓN

La organización debe proporcionar un mecanismo para que el personal reporte eventos de seguridad de la información observados o sospechosos a través de canales apropiados de forma oportuna.



A07 CONTROLES FÍSICOS

A07 CONTROLES FÍSICOS

A.7.1

PERÍMETROS DE SEGURIDAD FÍSICA

Se deben definir y utilizar perímetros de seguridad para proteger las áreas que contienen información u otros activos asociados.

A.7.2

ENTRADA FÍSICA

Se deben proteger las áreas seguras mediante controles de entrada apropiados y puntos de acceso

A.7.3

ASEGURAMIENTO DE OFICINAS, SALAS E INSTALACIONES

Se debe diseñar y aplicar seguridad física para oficinas, salas e instalaciones.

A.7.4

MONITOREO DE SEGURIDAD FÍSICA

Las instalaciones deben ser continuamente monitoreadas contra accesos físicos no autorizados.

A07 CONTROLES FÍSICOS

A.7.5

PROTECCIÓN CONTRA AMENAZAS EXTERNAS Y AMBIENTALES

Se debe diseñar y aplicar protección física contra desastres naturales, ataques maliciosos o accidentes.

A.7.6

TRABAJO EN ÁREAS SEGURAS

Se deben diseñar y aplicar medidas de seguridad para trabajar en áreas seguras.

A.7.7

PANTALLA Y ESCRITORIO LIMPIO

Se debe definir y asegurar que se cumpla una política de escritorio limpio de papeles y medios de almacenamiento removibles y una política de pantalla limpia para las instalaciones de procesamiento de la información.

A07 CONTROLES FÍSICOS

A.7.8

UBICACIÓN Y PROTECCIÓN DE EQUIPO

El equipo debe estar situado con seguridad y protegido.

A.7.9

SEGURIDAD DE LOS EQUIPOS Y ACTIVOS FUERA DE LAS INSTALACIONES

Los activos que se encuentran fuera de las instalaciones deben estar protegidos.

A.7.10

MEDIOS DE ALMACENAMIENTO

Los medios de almacenamiento deben ser gestionados a través de su ciclo de vida durante la adquisición, uso, transporte y disposición de acuerdo con el esquema de clasificación de la organización y manejo requerido.

A07 CONTROLES FÍSICOS

A.7.11

SERVICIOS PÚBLICOS

El equipo debe estar protegido contra fallas de energía y otras interrupciones causadas por fallas en los servicios públicos.

A.7.12

SEGURIDAD DEL CABLEADO

El cableado de energía y telecomunicaciones que transporten datos o soporten los servicios de la información deben protegerse de interceptación, interferencia o daño.

A.7.13

MANTENIMIENTO DEL EQUIPO

El equipo debe mantenerse correctamente para asegurar su continua disponibilidad, integridad y confidencialidad de la información.



A07 CONTROLES FÍSICOS

A.7.14

DISPOSICIÓN O REUTILIZACIÓN SEGURA DEL EQUIPO DISPOSICIÓN O REUTILIZACIÓN SEGURA DEL EQUIPO

Todos los elementos del equipo que contienen medios de almacenamiento deben ser verificados para garantizar que cualquier dato sensible y software licenciado ha sido eliminado o sobrescrito de manera segura previo a su disposición o reutilización.



A08 CONTROLES TECNOLÓGICOS

A08 CONTROLES TECNOLÓGICOS

A.8.1

DISPOSITIVOS DE PUNTO FINAL DE USUARIO

La información almacenada, procesada o disponible en dispositivos hardware de usuarios debe ser protegida.

A.8.2

DERECHOS DE ACCESO PRIVILEGIADO

La asignación y uso de los derechos de acceso privilegiado deben restringirse y controlarse.

A.8.3

RESTRICCIÓN DE ACCESO A LA INFORMACIÓN

Se debe restringir el acceso a la información y activos asociados de acuerdo con lo establecido en la política del tema específico de control de acceso

A08 CONTROLES TECNOLÓGICOS

A.8.4

ACCESO AL CÓDIGO FUENTE DEL PROGRAMA

El acceso al código fuente por vía escrita o de lectura, herramientas de desarrollo y bibliotecas de software deben ser apropiadamente gestionadas

A.8.5

AUTENTICACIÓN SEGURA

Las tecnologías y procedimientos de autenticación segura deben ser implementadas con base en las restricciones de acceso a la información y la política del tema específico de control de acceso.

A.8.6

GESTIÓN DE CAPACIDAD

El uso de recursos debe monitorearse, afinarse para realizar proyecciones de los requisitos futuros de la capacidad.

A08 CONTROLES TECNOLÓGICOS

A.8.7

PROTECCIÓN CONTRA MALWARE

La protección contra malware debe ser implementada y apoyada por la consciencia apropiada del usuario.

A.8.8

GESTIÓN DE VULNERABILIDADES TÉCNICAS

Se debe obtener información acerca de las vulnerabilidades técnicas de los sistemas de información que están siendo utilizados de manera oportuna, evaluar la exposición de la organización a tales vulnerabilidades y tomar medidas apropiadas para tratar los riesgos asociados.

A.8.9

GESTIÓN DE LA CONFIGURACIÓN

Las configuraciones, incluyendo configuraciones de seguridad, hardware, software, servicios y redes deben ser establecidas, documentadas, implementadas, monitoreadas y revisadas.

A08 CONTROLES TECNOLÓGICOS

A.8.10

ELIMINACIÓN DE INFORMACIÓN

La información almacenada en los sistemas de información, dispositivos o en cualquier otro medio de almacenamiento debe ser eliminada cuando ya no sea necesaria.

A.8.11

ENMASCARAMIENTO DE DATOS

El enmascaramiento de datos debe ser utilizado debe ser usado de acuerdo con la política del tema específico de control de acceso y otras políticas relacionadas y las necesidades del negocio, tomando en consideración la legislación aplicable.

A.8.12

PREVENCIÓN DE FUGA DE DATOS

Las medidas de prevención de fuga de datos deben ser aplicadas a los sistemas, redes y cualquier otro dispositivo que procese, almacene o transmita información sensible.

A08 CONTROLES TECNOLÓGICOS

A.8.13

RESPALDOS DE LA INFORMACIÓN

Copias de respaldos de la información, software e imágenes de sistemas deben realizarse y probarse regularmente de acuerdo con la política de respaldos acordada.

A.8.14

REDUNDANCIA DE LAS INSTALACIONES DE PROCESAMIENTO DE INFORMACIÓN

Las instalaciones de procesamiento de información se deben implementar con suficiente redundancia para cumplir los requisitos de disponibilidad.

A.8.15

INICIOS DE SESIÓN

Los inicios de sesión que registren actividades, excepciones faltas u otros eventos relevantes deben ser presentados, almacenados, protegidos y analizados.

A08 CONTROLES TECNOLÓGICOS

A.8.16

MONITOREO DE ACTIVIDADES

Las redes, sistemas y aplicaciones deben ser monitoreados de comportamientos maliciosos y se deben tomar las acciones necesarias para evaluar potenciales incidentes de seguridad.

A.8.17

SINCRONIZACIÓN DEL RELOJ

Los relojes de todos los sistemas de procesamiento de la información dentro de la organización deben estar sincronizados con una sola fuente de tiempo de referencia aprobada.

A.8.18

USO DE PRIVILEGIOS DE LOS PROGRAMAS DE UTILIDADES

El uso de programas de utilidades que puedan ser capaces de anular los controles del sistema y de las aplicaciones debe estar restringido y estrechamente controlado.

A08 CONTROLES TECNOLÓGICOS

A.8.19

INSTALACIÓN DE SOFTWARE EN SISTEMAS OPERACIONALES

Se deben implementar procedimientos y medidas para controlar la instalación de software en sistemas operacionales

A.8.20

SEGURIDAD DE LAS REDES

Las redes deben gestionarse y controlarse para proteger la información en los sistemas y aplicaciones

A.8.21

SEGURIDAD EN LOS SERVICIOS DE RED

Los mecanismos de seguridad, niveles de servicio y los requisitos de gestión para todos los servicios de la red deben identificarse, implementarse y monitorearse

A08 CONTROLES TECNOLÓGICOS

A.8.22

SEGREGACIÓN EN REDES

Los grupos de servicios de información, usuarios y sistemas de información deben estar segregados en las redes de la organización.

A.8.23

FILTRADO WEB

El acceso a sitios web externos debe ser controlado para reducir la exposición a contenido malicioso

A.8.24

USO DE CRIPTOGRAFÍA

Se deben definir e implementar reglas para el uso efectivo de la criptografía, incluyendo gestión de claves/llaves criptográficas.

A08 CONTROLES TECNOLÓGICOS

A.8.25

DESARROLLO SEGURO DEL CICLO DE VIDA

Deben establecerse y aplicarse reglas para el desarrollo seguro de software y sistemas.

A.8.26

APLICACIÓN DE REQUISITOS DE SEGURIDAD

Los requisitos relacionados con la seguridad de la información deben ser identificados, especificados y aprobados durante el desarrollo o adquisición de aplicaciones

A.8.27

PRINCIPIOS DE ARQUITECTURA E INGENIERÍA EN SISTEMAS SEGUROS

Se deben establecer, documentar, mantener y aplicar principios de ingeniería para sistemas seguros a cualquier desarrollo de implementación de sistemas de información.



A08 CONTROLES TECNOLÓGICOS

A.8.28

CODIFICACIÓN SEGURA

Los principios de codificación segura deben ser aplicados al desarrollo de software.

A.8.29

PRUEBAS DE SEGURIDAD PARA EL DESARROLLO Y ACEPTACIÓN

Se deben definir e implementar procesos de pruebas de seguridad durante el desarrollo del ciclo de vida.

A.8.30

DESARROLLO DE SUBCONTRATACIÓN (OUTSOURCING)

La organización debe supervisar y monitorear directamente las actividades del desarrollo de la subcontratación (outsourcing).

A08 CONTROLES TECNOLÓGICOS

A.8.31

SEPARACIÓN DE ENTORNOS DE DESARROLLO, PRUEBA Y PRODUCCIÓN

Se deben separar y mantener la seguridad de los entornos de desarrollo, prueba y producción.

A.8.32

GESTIÓN DEL CAMBIO

Los cambios a las instalaciones de procesamiento de información y sistemas de información deben estar sujetos a procedimientos de gestión de cambio.

A.8.33

INFORMACIÓN DE PRUEBAS

La información de las pruebas debe ser apropiadamente seleccionada, protegida y gestionada.

A08 CONTROLES TECNOLÓGICOS

A.8.34

PROTECCIÓN DE SISTEMAS DE INFORMACIÓN DURANTE AUDITORÍA

Las auditorías y otras actividades de aseguramiento que impliquen evaluación de sistemas operacionales deben ser planeadas y acordadas entre el auditor y el administrador correspondiente